
From Law to Action: Neuro-Symbolic Runtime Enforcement for MCP Agents

Anonymous Author(s)

Affiliation

Address

email

Abstract

1 We evaluate a bounded runtime-checking question for tool effects that stand in
2 for generated-code side effects: under explicit ENFORCE at one pre-invocation
3 Model Context Protocol (MCP) handler, can an independently observed sandbox
4 mutation that lacks a matching context-bound admission be prevented, while a
5 matched admitted case still performs useful permitted work? Legal documents,
6 CVE-linked vulnerability and repair records, and SkillCenter procedures compile
7 into Legal, Security, and Intent IR. Those IRs are models with distinct authority,
8 not proofs of legal correctness, universal vulnerability absence, or permission. On
9 an admitted $60 \times 5 \times 3$ matrix of frozen modeled-policy probes, full enforcement
10 observed 0/90 policy-forbidden handler effects and completed 90/90 allowed
11 useful work. Unguarded execution and model-free prompt/retrieval labels observed
12 90/90 forbidden effects. Lightweight policy plus UCAN leaked 33/90. Expert
13 legal fidelity, human agreement, and closed-loop model planning were not collected
14 or executed and are withdrawn rather than filled. Closest systems—reference
15 monitors, proof-carrying authorization, Catala, UCAN/Cedar, AgentSpec, Progent,
16 CaMeL, and AgentDojo—motivate implementable arm classes; none is a scored
17 baseline here.

18 1 Introduction

19 An autonomous agent can follow a useful procedure and still violate a legal restriction, reproduce
20 a known vulnerability, or act outside its delegated authority. A safeguard placed only in the model
21 prompt cannot distinguish these cases reliably. The implementation described here places source-
22 grounded constraints and a separate authorization boundary between proposed actions and a protected
23 MCP handler. MCP supplies tool discovery and invocation; application implementations remain
24 responsible for enforcing security requirements [1, 2].

25 The method begins before a tool call. A legal collection supplies normative constraints, a vulnerability-
26 and-fix collection supplies security evidence, and a skill collection supplies descriptions of intended
27 procedures. These become three intermediate representations (IRs), not one undifferentiated retrieval
28 index. Formalization produces typed logic views and proof obligations. The runtime joins the results
29 against one exact invocation, then checks authorization again before the effect. This design combines
30 semantic compilation, proof search, capability security, and stateful execution rather than asking a
31 language model to certify its own behavior.

32 The evaluated workshop contribution is that bounded mediation test [3]. It is not a new authorization
33 logic, a new legal language, or a first agent runtime monitor. AgentSpec, Progent, and CaMeL
34 already supply runtime rules, tool-privilege checks, and capability isolation [4–6]; Catala compiles
35 expert-authored law [7]; AgentDojo measures utility beside attacks [8]. We cite those primary sources
36 as comparison classes. We do not execute them as experimental arms. Source adapters, constraint

37 compilation, DuckDB-backed supervision, and content-addressed evidence are implementation
38 context. Legal IR is a lossy model of selected facets, not a proof of legal correctness. Default OFF
39 pass-through and in-memory consumption are not enforcement. The scored study uses one sandbox
40 handler, independently observed filesystem-journal effects, and a frozen modeled policy. It does not
41 evaluate model-generated programs, expert legal interpretation, or universal prevention.

42 2 Related work

43 The scored evaluation asks whether an independently observed handler effect is denied at one explicit
44 ENFORCE delegate while matched admitted work remains executable. The comparison below is a
45 literature comparison on that question. No cited external system was executed as a scored arm.

46 **Runtime enforcement.** Complete mediation requires a check at every access to a protected resource
47 [9]. Security automata and inlined or editing monitors describe which policies a runtime mechanism
48 can enforce [10–13]. Those mechanisms inspect program actions. They do not compile legal or
49 vulnerability sources, and they do not count useful MCP-handler work. AgentSpec supplies agent
50 runtime triggers, predicates, and enforcement rules [4]. Progent checks symbolic tool privileges and
51 classifies policy updates using an SMT solver [5]. These direct precedents rule out claims that this
52 paper introduces agent runtime rules or guarded privilege updates. Neither system was benchmarked
53 here.

54 **Proof-carrying admission.** Proof-carrying code [14] and proof-carrying authentication [15] re-
55 quire a checker to accept a proof before running untrusted code or granting a request. Translation
56 validation and CompCert separate a translator from a checked proof [16, 17]. A content identifier or
57 a `proof_cid` in an envelope is not that check.

58 **Executable law is not checked derivation.** Encoding a statute as a logic program already performs
59 an interpretation [18–20]. Catala compiles literate legal specifications to programs and has been
60 applied to tax law [7, 21]. It is the closest executable-law precedent. It is not an agent runtime. Legal
61 IR in this paper is a bounded, lossy compilation of selected facets; unsupported facets and expert
62 applicability remain labeling problems, not theorems.

63 **Capabilities and application-level MCP enforcement.** Object capabilities, attenuating caveats,
64 relation tuples, and analyzable policy languages [22–25] justify a lightweight grant check. UCAN
65 specifies signed delegated capabilities [26]. MCP supplies tool invocation; its authorization document
66 specifies OAuth 2.1 resource-server roles and requires implementations to follow OAuth 2.1 security
67 best practices [1, 2]. That protocol is not a generated-code effect monitor. A signature, a CID, or a
68 peer identity is not a generated-code effect observation.

69 **Verifiable coding and agent-security evaluations.** Functional correctness and issue resolution
70 [27, 28] measure useful coding work without gated forbidden-effect counters. Closed-loop verified
71 generation and autoformalization [29–31] target specs and prover artifacts, not this handler route.
72 AgentDojo, ToolEmu, InjecAgent, τ -bench, and AgentHarm [8, 32–35] measure tool-use attacks,
73 emulated risk, injection, policy following, or harm. CaMeL isolates agent data flow with capabilities
74 [6]. They motivate reporting utility beside forbidden effects. They were not run here.

75 **Implementable arms, not imported suites.** The matched arms are mechanism classes in this stack:
76 an unguarded handler (A0); inert prompt and retrieval labels as model-free equivalence controls
77 (A1, A2); a qualified policy and capability verifier (A3); and explicit ENFORCE with exact context
78 binding, a qualified proof route, and durable consumption (A4). Prompt or retrieval efficacy is not
79 identified in the model-free study. CVEfixes is a vulnerability/fix collection [36], not a runtime.
80 DuckDB/Quack, IPFS, and libp2p [37–39] are operational substrates. The workshop fit is runtime
81 checking of a proposed effect before a protected mutation [3], not a claim that every cited system was
82 benchmarked.

83 3 Corpus sources and compilation into IRs

84 The evaluated source freeze is 30 lineage families and 60 cases: six legal documents, 12 CVE
85 repository families with vulnerable/fixed pairs, and 12 SkillCenter families with a base procedure and
86 an adversarial variant. Physical reads used to reserve that freeze were six legal documents, 4329 rows
87 from the first CVEfixes shard, and 1182 SkillCenter index/content rows in the read bundle. Release-
88 card totals (municipal harvests, national-legislation cards, 12,987 CVEfixes input rows, 216,972
89 SkillCenter physical records) remain unrecounted background and are not evaluated populations.
90 Appendix A records family-level provenance requirements. No worldwide-coverage claim follows
91 from the bounded sample.

92 Legal documents compile through a restricted seven-field grammar (modality, actor, action, object,
93 conditions, exceptions, temporal qualifiers) with source maps and declared losses. Compilation is
94 inspectable. Source-to-rule fidelity remains a separate validation requirement and was not expert-
95 reviewed in this study. Executable-law work such as Catala supplies a relevant precedent [7]; it is not
96 an agent runtime or a handler-effect observer.

97 CVEfixes links vulnerability records to source repositories and fixes [36]. The inspected release pins
98 hitoshura25/cvefixes at d4f5c4ea65329d9ccbb8a3b3149e5d06eda5edb2. The adapter constructs
99 a canonical Security IR declaration and rejects wildcard scope and inserted authority grants. Vulnera-
100 ble code is a positive control for a candidate restriction; fixed code is a negative control for that restric-
101 tion. A fix does not certify that all other vulnerabilities are absent. Runtime `cve_security_gate`
102 maps declared intent and independently extracted handler effects into the same Security IR root.
103 Incomplete mappings remain unknown.

104 SkillCenter supplies procedural Markdown. The bounded reader opens upstream SQLite bundles read-
105 only, disables extension loading, and never executes commands appearing in a skill. The inspected
106 source is Tommysha/skillcenter-bundles at f9dd4fec3c86d85ebf116c7408ac5ce602c418a1. In-
107 tent IR distinguishes goals, guards, effects, and control edges, with source spans and grounded-versus-
108 inferred status. A procedure’s word “permitted” is a source assertion, not a capability. The default
109 skill path is a deterministic structural normalizer. No trained encoder was pinned or evaluated.

110 The three families share identity, provenance, and obligation contracts. They do not share an ontology
111 or grant authority to one another. Sparse, dense, and graph retrieval may nominate evidence; hard
112 applicability and exact identity determine whether it may be used. Retrieval engineering is not a
113 measured token-saving result.

Table 1: Three source-to-IR paths. None of the source streams directly supplies execution authority.

Source stream	Derived semantics	Contribution to an action decision
Legal texts and versions	Norms, scope, authority, exceptions, temporal applicability	Which represented legal constraints apply?
CVE-linked code and fixes	Threat assumptions, effects, mitigations, scoped prohibition candidates	Does the proposed or generated behavior violate a reviewed security constraint?
Skill Markdown and metadata	Goals, actions, guards, effects, verification, control flow	What is the agent trying to do, and what effects does its procedure require?

114 4 Logic families, joining, and the protected route

115 An IR is a domain representation; a logic family determines how its statements are interpreted; a
116 prover is a backend that checks a supported encoding. A family’s presence in a registry does not mean
117 every formula or backend is qualified. Appendix B records the broader map. The benchmark-required
118 proof-oriented route actually executed is a QF_BOOL / propositional SAT encoding of a Hoare-style
119 security invariant, with SymPy DPLL as a child process and an independent exhaustive truth-table
120 checker. Both emit satisfiability authority only. SAT-only, simulated, policy-only, and monitor

121 evidence cannot satisfy a `theorem_proof` requirement. QF_LIA interpolation and interactive
 122 kernels were not selected and were not available on the sealed validation path.

Table 2: Roles of native views. Only the QF_BOOL SAT route was qualified for the scored study.

Logic or formal view	Implemented role in the stack	Qualified in this evaluation
Hoare-style contracts and SAT	Preconditions, postconditions, and a propositional invariant over grant and forbidden effect	QF_BOOL SAT plus independent truth table; satisfiability only
Rule/policy and capability views	Bounded authorization declarations and signed UCAN grants	Real Ed25519 verification in A3/A4; not a theorem
Deontic / temporal / event-calculus tags	Native representations and compiler bridges	Registered; not a live scored backend
Interactive proof kernels	Lean/Coq/Isabelle adapters	Unavailable on the sealed path; no invented kernel result

123 An `InvocationIntentEnvelope` commits to source identity, tenant, actor, audience, tool/version, argu-
 124 ments, proposed effects, environment, nonce, and relevant roots. Trusted adapters bind the effect
 125 description to the actual operation. The constraint compiler joins Legal, Security, and Intent checks
 126 against that exact invocation. A favorable score cannot offset a failed hard constraint.

127 The selected protected route is `PreInvocationEnforcer.authorize_and_delegate` in explicit
 128 ENFORCE around `SandboxExportHandler.export_json`. Independent filesystem-journal counters
 129 observe handler effects. A permissible candidate still requires a current grant for the exact actor, tool,
 130 resource, and bounds. The runtime revalidates and consumes the permitted use immediately before
 131 delegation. Replay, expiry, wrong audience, changed arguments, undeclared effects, and changed
 132 roots are denials at that boundary. DuckDB with a typed Quack owner records operational progression
 133 for the A4 deployment; the default in-memory store is a labeled contrast only. IPFS names immutable
 134 bytes [38]; `libp2p` carries framed MCP messages [39]; UCAN checks signed attenuated delegation
 135 [26]. None of those substrates is itself the scored safety result. Kit’s `AuthorizationGate` is a
 136 related policy gate and is not the selected safety claim.

137 5 Evaluation

138 5.1 Frozen protocol and automated evidence scope

139 The predeclared fixed-action study uses 30 source-lineage families and 60 cases (six legal families,
 140 12 CVE repository pairs, 12 SkillCenter families), split 6/6/18 into development, calibration, and final
 141 by source lineage [36]. Each family contributes one policy-allowed and one policy-forbidden case.
 142 Five matched arms share the same candidate identifiers, arguments, and sandbox handler: unguarded
 143 execution (A0); inert prompt-text and retrieval-context labels as model-free equivalence controls
 144 (A1, A2); lightweight policy plus real Ed25519 UCAN verification (A3); and explicit ENFORCE with
 145 exact-context binding, a qualified QF_BOOL SAT job, and file-backed DuckDB consumption (A4).
 146 Seeds 104729, 104759, and 104761 yield a $60 \times 5 \times 3 = 900$ -cell matrix. The independent unit is the
 147 lineage family. Allowed and forbidden labels are the frozen modeled policy and machine-checkable
 148 behavior contract, not real-world legality.

149 Outside reviewers were not a run dependency. Expert legal applicability, exception fidelity, semantic
 150 accuracy, inter-annotator agreement, and legal validity were not collected and are not scored. Optional
 151 author reading, if it occurs later, is non-independent and is not human gold. Generated interpretations
 152 remain predictions. The LA-009 skill-validator comparison of 18/18 is shared-producer confor-
 153 mance: the same Intent IR decoder and schema functions already invoked by the normalizer, not an
 154 independent checker.

155 5.2 Source-to-IR contracts

156 Every frozen case has a retained prediction, failure, or unsupported record; cohorts were not changed
157 after outcomes. Quoted source-span linkage held on 60/60 cases. Parse or schema validity held
158 on 50/60. The scoped machine-contract coverage was 60/60. Four CVE adapter errors and six
159 skill-policy-blocked unsupported rows remain in the denominator accounting. CVE source-difference
160 observation was 24/24 under an independent behavior-contract producer; polarity remains unknown
161 on all 24 cases (12 pairs), and transfer to the `export_json` handler is unsupported. Implementation
162 agreement is not semantic accuracy. These measurements replace the original expert-reviewed
163 legal-fidelity row, which is withdrawn as unmeasured (Table E1).

164 5.3 Admitted protected-effect and useful-work results

165 The primary empirical study is the LA-029 operator matrix: 900 scientific cells, all resource-
166 qualified, with independent filesystem-journal effect counters. Compact rows do not retain
167 full per-cell proof or capability payloads; pinned executed mechanisms, effect counters, and
168 the shared durable-store identity support the runtime observations. Implementation revision
169 `ee6d73c4a5fc30d05ec4e787fdeb46d6701a4f947b7c874aecabf603e31ce06c`. Model calls
170 were 0. Independent human gold is false. Two original false host admissions (schedule indices
171 459 and 560) remain labeled as such. Two container-startup recoveries at indices 591 and 625 were
172 charged once after proof that science had not started; scientific retries were 0. Host attempts total
173 902. Measured descendant-inclusive group CPU was 1608.817478 seconds, under the frozen 18,000-
174 second stop. Peak cell memory was 274812928 bytes; maximum individual-cell wall-to-exit was
175 18.022665493073873 seconds. The startup recoveries used prospective cumulative-active allowances:
176 failed-startup plus recovered-run wall totaled 11.766052 seconds at index 591 and 19.793533 seconds
177 at index 625. Separate operator pause gaps were not active runtime; these amendments do not claim
178 an uninterrupted original absolute 20-second interval.

179 Table 3 reports the admitted rates. On the held-out final split (18 families; 54 forbidden-labelled
180 and 54 allowed-labelled attempts per arm), A4 observed 0/54 policy-forbidden effects and com-
181 pleted 54/54 allowed useful work with 0/54 false denials. Across the full admitted matrix the
182 same pattern holds: A4 0/90 forbidden effects and 90/90 allowed useful work; A0–A2 90/90
183 forbidden effects on forbidden-labelled attempts; A3 33/90 forbidden effects. A1 and A2 match
184 A0 (final-split paired family difference 0, cluster-bootstrap 95% interval $[0, 0]$) and therefore re-
185 main instrumentation/equivalence controls, not prompt or retrieval efficacy. Final-split paired fam-
186 ily differences in forbidden-effect rate are -0.6666666666666666 for A3 versus A0 (percentile
187 95% $[-0.8888888888888888, -0.4444444444444444]$), -1.0 for A4 versus A0 ($[-1.0, -1.0]$), and
188 -0.3333333333333333 for A4 versus A3 ($[-0.5555555555555555, -0.1111111111111111]$). A
189 degenerate zero interval does not establish population-level absence or universal prevention.

190 The handler under test accepts a declarative `export_json` instruction. Independently observed
191 effects are sandbox filesystem-journal events, not AST extraction from model-generated source. No
192 scientific generative model was pinned.

193 5.4 Negative results and scoped omissions

194 A3 is not equivalent to A4. The 33 A3 leaks (decision allow, observed forbidden ef-
195 fect) concentrate on `wrong_date_or_jurisdiction` (9), `forged_receipt` (6), `replay` (6),
196 `changed_root_clock_or_environment` (6), and `undeclared_handler_effect` (6). On the
197 final split the residual classes are replay, changed root/clock/environment, and wrong date/jurisdiction
198 (6 each). A4 denied those identities. SAT/UNSAT on the selected QF_BOOL route has satisfiability
199 authority only; it cannot authorize a `theorem_proof` allow. Z3, cvc5, Vampire, E, Lean, Coq/Rocq,
200 Isabelle, and QF_LIA interpolation were absent from the sealed validation path and are not assigned
201 invented results.

202 Closed-loop generated-code planning (protocol RQ3) is explicitly withdrawn: 900/900 scheduled
203 cells were `not_started`, model calls 0, generated programs 0. Unstarted zeros are accounting, not
204 measured agent failure. Results are not pooled with the fixed-action matrix.

205 The original LA-015 compact log and its rescue remain protocol-unadmitted diagnostics; they are
206 not headline admitted rates. LA-017 paired mechanism ablations and LA-016/LA-017 comparison

Table 3: Admitted LA-029 fixed-action rates from independent effect counters. Forbidden-effect rate uses forbidden-labelled attempts; allowed-task success uses allowed-labelled attempts. Labels are the frozen modeled policy. Overall $n = 90$ forbidden-labelled and 90 allowed-labelled attempts per arm (180 decisions). Final $n = 54 + 54$.

Arm	Split	Forbidden effects	Allowed useful work	False denials
A0 unguarded	overall	90/90	90/90	0/90
A1 prompt label	overall	90/90	90/90	0/90
A2 retrieval label	overall	90/90	90/90	0/90
A3 policy+UCAN	overall	33/90	90/90	0/90
A4 ENFORCE	overall	0/90	90/90	0/90
A0 unguarded	final	54/54	54/54	0/54
A3 policy+UCAN	final	18/54	54/54	0/54
A4 ENFORCE	final	0/54	54/54	0/54

wording are protocol-unadmitted diagnostic evidence and do not establish admitted model efficacy. LA-018 cold/warm/stale timings are a development A4 instrumentation study ($n = 12$ per condition; cold mean end-to-end wall 0.012326 s, warm 0.006635 s, stale-root and stale-clock 0.00322 s with 12/12 stale-evidence flags; model tokens unobserved; no price conversion) and are not a 900-cell rescore. LA-020 twelve-step traces are separate diagnostic replays of frozen A4 identities, not additional scored cells. Qualification suites for mediation, DuckDB consumption, and local stdio/HTTP/libp2p parity passed their selected-claim cases and remain qualification, not scored arm rates. Wide-area publication and an IPFS daemon were not available.

Admitted rates are taken from `results/fixed_actions_admitted/summary.json` together with the matching cost report and claim guidance. LA-019 generated tables and figures analyze the historical unadmitted log and are not substituted for that admitted summary.

6 Limitations and modeling assumptions

Legal IR is a lossy model of selected facets (modality, actor, action, object, conditions, exceptions, temporal qualifiers), not the law and not a proof of legal correctness. Unsupported constructs must not disappear into a successful admission. Expert legal fidelity, human agreement, and legal-validity rates were not collected; they remain unmeasured rather than filled with compiler agreement or generated labels. Security IR is a scoped candidate prohibition. A CVE or CWE identifier, a fix, or a source-difference observation is not universal vulnerability absence and is not transfer to unrelated code. Skill Markdown is untrusted data; a procedure’s word “permitted” is not a capability.

Complete mediation is claimed only for `SupervisorPreInvocationEnforcement.authorize_and_delegate` in explicit ENFORCE around one benchmark-owned `BoundedExportHandler.export_json` sandbox mutation. Default OFF is pass-through. The default in-memory consumption store is not the restart-safety configuration; A4 used a file-backed DuckDB typed Quack owner. A DuckDB commit is not remote exactly-once evidence. Unprotected, observational, and nonidentical routes were exercised in qualification and excluded from the safety claim. Local stdio, loopback HTTP, and loopback libp2p parity do not establish wide-area transport.

The selected proof route is propositional SAT with an independent truth-table checker. Satisfiability is not a kernel theorem. Compact admitted records do not retain full per-cell proof or capability payloads. The evaluated handler consumes a declarative export instruction; closed-loop model-generated programs were not executed. No trained skill normalizer or encoder was evaluated. Release-card corpus totals were not independently recounted and are not evaluated populations. Optional author review is not a prerequisite for this draft, is not independent annotation, and cannot replace the frozen automated evidence.

240 7 Conclusion

241 On one explicit ENFORCE sandbox route, independently observed forbidden handler effects were
242 prevented for every frozen policy-forbidden probe while matched admitted work still succeeded.
243 Lightweight policy plus UCAN was not sufficient for the residual mutation classes. Unguarded
244 execution and inert prompt or retrieval labels were not sufficient either. The result is a bounded,
245 policy-relative verifiable-coding measurement [3], not superiority to Catala, AgentSpec, Progent,
246 CaMeL, AgentDojo, or any other listed system, and not a claim of legal correctness, expert agreement,
247 or closed-loop generated-program control. Those latter studies remain unmeasured or withdrawn.
248 Optional author review is not required to generate this evidence-scoped draft and would not be
249 independent human validation.

References

- [1] Model Context Protocol contributors. Model Context Protocol specification, revision 2025-11-25, 2025. URL <https://modelcontextprotocol.io/specification/2025-11-25>. Accessed 6 September 2026 (reconstructed bibliography). Live document retrieved 12 September 2026 at the same URL; title: Specification - Model Context Protocol. Tool-invocation protocol, not a generated-code effect monitor.
- [2] Model Context Protocol contributors. Model Context Protocol: Authorization, revision 2025-11-25, 2025. URL <https://modelcontextprotocol.io/specification/2025-11-25/basic/authorization>. Accessed 6 September 2026 (reconstructed bibliography). Live document retrieved 12 September 2026; title: Authorization - Model Context Protocol. Specifies OAuth 2.1 resource-server roles and requires implementations to follow OAuth 2.1 security best practices. It is not a generated-code effect observer.
- [3] NeurIPS 2026 Workshop on AI for Verifiable Coding organizers. Call for papers, 2026. URL <https://vericodegen.github.io/cfp.html>. Live page retrieved 12 September 2026. Title: Call for Papers — VeriCodeGen: AI for Verifiable Coding at NeurIPS 2026. Research track: main text at least 4 and at most 9 pages excluding references and appendices; official 2026 workshop template; double-blind submission including linked artifacts; methodology-essential LLM disclosure; non-archival workshop. Listed topics include runtime monitoring of agents, verified guardrails, constrained tool use, and access-control policies. Paper deadline 13 September 2026 AoE; camera-ready 14 October 2026; workshop 12 December 2026, Atlanta.
- [4] Haoyu Wang, Christopher M. Poskitt, and Jun Sun. Agentspec: Customizable runtime enforcement for safe and reliable llm agents, 2025. URL <https://arxiv.org/abs/2503.18666v3>. Version 3, 31 July 2025. arXiv abstract retrieved 12 September 2026; first submitted 24 March 2025. Operator metadata check 11 September 2026. Not benchmarked in this paper.
- [5] Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing ai agents with privilege control, 2025. URL <https://arxiv.org/abs/2504.11703v3>. Version 3 revised 14 May 2026; first submitted 16 April 2025. arXiv abstract retrieved 12 September 2026. Operator metadata check 11 September 2026. Not benchmarked in this paper.
- [6] Edoardo Debenedetti, Iliia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design, 2025. URL <https://arxiv.org/abs/2503.18813v2>. CaMeL capability isolation for LLM agents. Version 2, 24 June 2025; arXiv abstract retrieved 12 September 2026. Operator metadata check 11 September 2026. Not executed as a scored arm here.
- [7] Denis Merigoux, Nicolas Chataing, and Jonathan Protzenko. Catala: A programming language for the law. *Proceedings of the ACM on Programming Languages*, 5(ICFP):77:1–77:29, 2021. doi: 10.1145/3473582. Crossref retrieved 12 September 2026. Crossref page field is 1-29; PACMPL article-number pagination 77:1–77:29 is retained from the reconstructed bibliography.
- [8] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, pages 82895–82920, 2024. doi: 10.52202/079017-2636. Crossref retrieved 12 September 2026. arXiv abstract retrieved 12 September 2026; submitted 19 June 2024. Datasets and Benchmarks track. Utility versus attack-success in dynamic tool environments; not this paper’s sandbox-handler counters.
- [9] Jerome H. Saltzer and Michael D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975. doi: 10.1109/PROC.1975.9939. Crossref retrieved 12 September 2026.
- [10] Fred B. Schneider. Enforceable security policies. *ACM Transactions on Information and System Security*, 3(1):30–50, 2000. doi: 10.1145/353323.353382. Crossref retrieved 12 September 2026.

- [11] Úlfar Erlingsson and Fred B. Schneider. IRM enforcement of Java stack inspection. In *Proceeding of the 2000 IEEE Symposium on Security and Privacy*, pages 246–255. IEEE, 2000. doi: 10.1109/SECPRI.2000.848461. Crossref retrieved 12 September 2026. IEEE container title uses “Proceeding” rather than “Proceedings”.
- [12] Jay Ligatti, Lujo Bauer, and David Walker. Edit automata: enforcement mechanisms for run-time security policies. *International Journal of Information Security*, 4(1-2):2–16, 2005. doi: 10.1007/s10207-004-0046-8. Crossref retrieved 12 September 2026. Issue is 1-2.
- [13] Kevin W. Hamlen, Greg Morrisett, and Fred B. Schneider. Computability classes for enforcement mechanisms. *ACM Transactions on Programming Languages and Systems*, 28(1):175–205, 2006. doi: 10.1145/1111596.1111601. Crossref retrieved 12 September 2026. Corrected from the non-resolving identifier 10.1145/1111596.1111603.
- [14] George C. Necula. Proof-carrying code. In *Proceedings of the 24th ACM SIGPLAN-SIGACT Symposium on Principles of Programming Languages*, POPL ’97, pages 106–119. ACM, 1997. doi: 10.1145/263699.263712. Crossref retrieved 12 September 2026.
- [15] Andrew W. Appel and Edward W. Felten. Proof-carrying authentication. In *Proceedings of the 6th ACM Conference on Computer and Communications Security*, CCS ’99, pages 52–62. ACM, 1999. doi: 10.1145/319709.319718. Crossref retrieved 12 September 2026.
- [16] Amir Pnueli, Michael Siegel, and Eli Singerman. Translation validation. In *Tools and Algorithms for the Construction and Analysis of Systems*, volume 1384 of *Lecture Notes in Computer Science*, pages 151–166. Springer, 1998. doi: 10.1007/BFb0054170. Crossref retrieved 12 September 2026. TACAS 1998, LNCS 1384.
- [17] Xavier Leroy. Formal verification of a realistic compiler. *Communications of the ACM*, 52(7):107–115, 2009. doi: 10.1145/1538788.1538814. Crossref retrieved 12 September 2026.
- [18] M. J. Sergot, F. Sadri, R. A. Kowalski, F. Kriwaczek, P. Hammond, and H. T. Cory. The British Nationality Act as a logic program. *Communications of the ACM*, 29(5):370–386, 1986. doi: 10.1145/5689.5920. Crossref retrieved 12 September 2026.
- [19] Henry Prakken and Giovanni Sartor. Law and logic: A review from an argumentation perspective. *Artificial Intelligence*, 227:214–245, 2015. doi: 10.1016/j.artint.2015.06.005. Crossref retrieved 12 September 2026.
- [20] Christoph Benzmüller, Xavier Parent, and Leendert van der Torre. Designing normative theories for ethical and legal reasoning: LogiKEY framework, methodology, and tool support. *Artificial Intelligence*, 287:103348, 2020. doi: 10.1016/j.artint.2020.103348. Crossref retrieved 12 September 2026.
- [21] Denis Merigoux, Raphaël Monat, and Jonathan Protzenko. A modern compiler for the French tax code. In *Proceedings of the 30th ACM SIGPLAN International Conference on Compiler Construction*, CC 2021, pages 71–82. ACM, 2021. doi: 10.1145/3446804.3446850. Crossref retrieved 12 September 2026.
- [22] Mark S. Miller. *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control*. PhD thesis, Johns Hopkins University, 2006. PhD thesis; no DOI used. Object-capability discipline.
- [23] Arnar Birgisson, Joe Gibbs Politz, Úlfar Erlingsson, Ankur Taly, Michael Vrabie, and Mark Lentzner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Proceedings of the 2014 Network and Distributed System Security Symposium*, NDSS 2014. Internet Society, 2014. doi: 10.14722/ndss.2014.23212. Crossref retrieved 12 September 2026.
- [24] Ruoming Pang, Ramón Cáceres, Mike Burrows, Zhifeng Chen, Pratik Godiwala, Ankur Kapoor, Christopher J. Hill, Kamil Kowalczyk, Alexander Piwonka, David Ramadan, David Rosenthal, David Sun, Rodrigo Tuttle, Jason Wang, Aaron Weingarten, and Maya Zaks. Zanzibar: Google’s consistent, global authorization system. In *2019 USENIX Annual Technical Conference (USENIX ATC 19)*, pages 33–46. USENIX Association, 2019. URL <https://>

- 352 //www.usenix.org/conference/atc19/presentation/pang. USENIX ATC 2019. No
353 Crossref DOI required; official proceedings pagination 33–46.
- 354 [25] Joseph W. Cutler, Craig Disselkoen, Aaron Eline, Shaobo He, Kyle Headley, Michael Hicks,
355 Kesha Hietala, Eleftherios Ioannidis, John Kastner, Anwar Mamat, Darin McAdams, Matt
356 McCutchen, Neha Rungta, Emina Torlak, and Andrew Wells. Cedar: A new language for
357 expressive, fast, safe, and analyzable authorization. *Proceedings of the ACM on Programming
358 Languages*, 8(OOPSLA1):670–697, 2024. doi: 10.1145/3649835. Crossref retrieved 12 Septem-
359 ber 2026. Corrected from inherited DOI 10.1145/3649817 (Cocoon, a different OOPSLA1
360 2024 paper) and inherited eprint 2403.04623 (a different arXiv record). Extended version:
361 arXiv:2403.04651, submitted 7 March 2024.
- 362 [26] UCAN contributors. User controlled authorization network (UCAN) specification, 2026. URL
363 <https://ucan.xyz/specification/>. Specification accessed 6 September 2026 (recon-
364 structured bibliography). Live document retrieved 12 September 2026; title: User Controlled
365 Authorization Network (UCAN) Specification. Signed delegation is distinct from theorem
366 checking and from exact proof-capability binding.
- 367 [27] Mark Chen, Jerry Tworek, Heewoo Jun, Qiming Yuan, Henrique Ponde de Oliveira Pinto,
368 Jared Kaplan, Harri Edwards, Yuri Burda, Nicholas Joseph, Greg Brockman, Alex Ray, Raul
369 Puri, Gretchen Krueger, Mikhail Petrov, Heidy Khlaaf, Girish Sastry, Pamela Mishkin, Brooke
370 Chan, Scott Gray, Nick Ryder, Mikhail Pavlov, Alethea Power, Lukasz Kaiser, Mohammad
371 Bavarian, Clemens Winter, Philippe Tillet, Felipe Petroski Such, Dave Cummings, Matthias
372 Plappert, Fotios Chantzis, Elizabeth Barnes, Ariel Herbert-Voss, William Hebgen Guss, Alex
373 Nichol, Alex Paino, Nikolas Tezak, Jie Tang, Igor Babuschkin, Suchir Balaji, Shantanu Jain,
374 William Saunders, Christopher Hesse, Andrew N. Carr, Jan Leike, Josh Achiam, Vedant Misra,
375 Evan Morikawa, Alec Radford, Matthew Knight, Miles Brundage, Mira Murati, Katie Mayer,
376 Peter Welinder, Bob McGrew, Dario Amodei, Sam McCandlish, Ilya Sutskever, and Wojciech
377 Zaremba. Evaluating large language models trained on code, 2021. arXiv abstract retrieved 12
378 September 2026; submitted 7 July 2021. HumanEval functional-correctness benchmark; not a
379 forbidden-effect mediation measurement.
- 380 [28] Carlos E. Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and
381 Karthik Narasimhan. SWE-bench: Can language models resolve real-world GitHub issues?
382 In *The Twelfth International Conference on Learning Representations*, 2024. ICLR 2024.
383 OpenReview forum VTF8yNQM66 (OpenReview API returned HTTP 403 on 12 September
384 2026). arXiv:2310.06770 abstract retrieved 12 September 2026; submitted 10 October 2023.
385 Issue-resolution utility, not gated handler-effect counters.
- 386 [29] Chuyue Sun, Ying Sheng, Oded Padon, and Clark Barrett. Clover: Closed-loop verifiable
387 code generation, 2023. arXiv abstract retrieved 12 September 2026; submitted 26 October
388 2023. No arXiv journal-ref or DOI on the abstract page. The inherited TU Wien ISBN item 27
389 identifier resolves to a different FMCAD 2024 paper (Toward Exhaustive Sequential Redundancy
390 Removal) and is not used.
- 391 [30] Kaiyu Yang, Aidan Swope, Alex Gu, Rahul Chalamala, Peiyang Song, Shixing Yu, Saad
392 Godil, Ryan J. Prenger, and Animashree Anandkumar. LeanDojo: Theorem proving with
393 retrieval-augmented language models. In *Advances in Neural Information Processing Systems*,
394 volume 36, pages 21573–21612, 2023. doi: 10.52202/075280-0944. Crossref retrieved 12
395 September 2026. Neighboring workshop topic; not this handler route.
- 396 [31] Yuhuai Wu, Albert Q. Jiang, Wenda Li, Markus N. Rabe, Charles Staats, Mateja Jamnik, and
397 Christian Szegedy. Autoformalization with large language models. In *Advances in Neural
398 Information Processing Systems*, volume 35, pages 32353–32368, 2022. doi: 10.52202/
399 068431-2344. Crossref retrieved 12 September 2026. arXiv abstract retrieved 12 September
400 2026; submitted 25 May 2022. Neighboring workshop topic; not this handler route.
- 401 [32] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann
402 Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an
403 LM-emulated sandbox. In *The Twelfth International Conference on Learning Representations*,
404 2024. ToolEmu. arXiv abstract retrieved 12 September 2026; submitted 25 September 2023.
405 Emulated tools are not independently observed handler mutations.

- [33] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506, 2024. doi: 10.18653/v1/2024.findings-acl.624. Crossref retrieved 12 September 2026. arXiv abstract retrieved 12 September 2026; submitted 5 March 2024.
- [34] Shunyu Yao, Noah Shinn, Pedram Razavi, and Karthik Narasimhan. τ -bench: A benchmark for tool-agent-user interaction in real-world domains, 2024. arXiv abstract retrieved 12 September 2026; submitted 17 June 2024. Policy-following success in tool-agent-user interaction; not a generated-code-to-protected-effect mediation measurement.
- [35] Maksym Andriushchenko, Alexandra Souly, Mateusz Dziemian, Derek Duenas, Maxwell Lin, Justin Wang, Dan Hendrycks, Andy Zou, Zico Kolter, Matt Fredrikson, Eric Winsor, Jerome Wynne, Yarin Gal, and Xander Davies. AgentHarm: A benchmark for measuring harmfulness of LLM agents. In *The Thirteenth International Conference on Learning Representations*, 2025. arXiv abstract retrieved 12 September 2026; submitted 11 October 2024. ICLR 2025. Harmfulness oracle; not this handler route.
- [36] Guru Bhandari, Amara Naseer, and Leon Moonen. CVEfixes: Automated collection of vulnerabilities and their fixes from open-source software. In *Proceedings of the 17th International Conference on Predictive Models and Data Analytics in Software Engineering*, pages 30–39, 2021. doi: 10.1145/3475960.3475985. Crossref retrieved 12 September 2026. Dataset, not a runtime.
- [37] DuckDB team. Quack: The duckdb client-server protocol, 2026. URL <https://duckdb.org/2026/05/12/quack-remote-protocol>. 12 May 2026. Accessed 6 September 2026 (reconstructed bibliography). Live document retrieved 12 September 2026; title: Quack: The DuckDB Client-Server Protocol. Operational-state substrate, not a safety theorem.
- [38] IPFS contributors. Content identifiers (CIDs), 2026. URL <https://docs.ipfs.tech/concepts/content-addressing/>. Documentation accessed 6 September 2026 (reconstructed bibliography). Live document retrieved 12 September 2026; title: Content Identifiers (CIDs) | IPFS Docs. Content identity is not publication, availability, or authorization.
- [39] libp2p contributors. libp2p connections specification, 2026. URL <https://github.com/libp2p/specs/blob/master/connections/README.md>. Specification accessed 6 September 2026 (reconstructed bibliography). Live document retrieved 12 September 2026; title: specs/connections/README.md at master. Transport identity is not a tool grant.

A Corpus lineage and release accounting

The inspected legal-source program includes public releases for the U.S. Code, state statutes, state administrative rules, Federal Register documents, state/local court rules, municipal/county codes, caselaw, and national legislation. The paper does not interpret a dataset title, a country registry entry, or a successful scrape as exhaustive coverage. The evaluated legal cohort is the six frozen documents. Card-reported municipal, Netherlands, and Belgian quantities have not been independently recounted and are not evaluated records.

Table A1: Legal source families and provenance requirements. Identifying publisher/dataset mappings belong in the private author record until camera-ready.

Source family	Representative inspected substrate	Required distinctions
Federal statutory law	U.S. Code sparse GraphRAG release, pinned source revision and official release point	Codification/release point, provision identity, amendment history and actual effective dates
State law	State-statute release and separate administrative-rule corpus	State, authority family, rule/statute distinction, missing jurisdictions and time coverage
Federal regulatory material	Federal Register collection	Proposed rule, final rule, notice, publication date, effective date and codified regulation are not interchangeable
Court rules and caselaw	Merged per-state court rules; Caselaw Access Project-derived collection	Court, jurisdiction, local/general rule, opinion treatment, holdings versus quotations
Municipal and county law	Multi-drop municipal harvest	Publisher, jurisdiction, per-drop discovery and failure counts; registry aliases may lag new release namespaces
International legislation	Netherlands corpus; Belgian official-source archive harvest; Argentine CID-keyed retrieval release	Language, source authority, consolidation date, archive capture, extraction version and incomplete coverage

The security source pins hitoshura25/cvefixes at d4f5c4ea65329d9ccbb8a3b3149e5d06eda5edb2. Graph nodes, edges, vectors, source rows, and unique CVEs are different populations. The evaluated CVE cohort is 12 repository families / 24 cases plus 84 excluded controls that never enter empirical sample counts. Evaluation includes the original vulnerable condition and the fixed negative control. Transfer to a proposed tool needs an explicit mapping; polarity remains unknown where the machine contract does not support it.

The SkillCenter source is Tommysha/skillcenter-bundles at f9dd4fec3c86d85ebf116c7408ac5ce602c418a1. SQLite is an untrusted input container, not the supervisor database. The evaluated skill cohort is 12 families / 24 cases. Index totals are not additional skills. Counts of available records do not establish counts of normalized Intent IR documents or safe procedures.

pinned source revision + raw artifact bytes
 -> bounded source record + content identity + use policy
 -> LegalIR | SecurityIR | IntentIR declaration
 -> native formal views + source map + loss/coverage diagnostics
 -> selected applicable constraints + exact invocation
 -> proof jobs + checked evidence + decision receipt
 -> authenticated capability / execution permit
 -> guarded effect + operational observation + durable record

464 B Logic-family and backend method map

465 A shared symbol table does not prove that two encodings preserve meaning. The TDFOL and
 466 DCEC Python cores establish parsable native representations. Resource-scoped authorization may be
 467 representable without invoking every family. Solver success, kernel acceptance, runtime monitors,
 468 and policy approval are non-interchangeable authority kinds. A timeout or unavailable backend is not
 469 a refutation.

Table B1: Logic families have different meanings. A shared symbol table or cross-view link does not prove that two encodings preserve those meanings.

Family/view	Representation and operations	What the paper may claim
Propositional and first-order	Boolean operators, typed terms, predicates, variables and quantifiers	Bounded facts and implications under the encoded vocabulary; not general natural-language understanding
F-logic / frame	Object identity, class membership, slots and relational inheritance	Structured semantic relations; not a cryptographic or temporal proof by itself
Deontic	Obligation, permission, prohibition	Explicit normative force under the selected axioms; an encoded permission is not an issued capability
Temporal / TDFOL	Always, eventually, next, until, since	Model time-sensitive requirements; a backend must support the actual fragment
Event calculus	Events, fluents, initiation/termination	Reason about transitions as represented; an observed event record is not a proof of every transition
Datalog / rule-policy	Bounded rules and authorization declarations	Rule derivation with an explicit open/closed-world convention, not automatic theorem authority
Hoare-style / SAT	Preconditions, postconditions, propositional invariants	The qualified QF_BOOL SAT route; SAT/UNSAT cannot authorize theorem_proof allows
Interactive proof	Native proof terms/scripts	Unavailable here; no invented kernel result

470 C Database, artifact, network, and capability boundaries

Table C1: Database and protocol responsibilities. Legacy or auxiliary indexes can exist without changing the canonical DuckDB control-plane description.

Layer	Technology and inspected role	Incorrect inference to avoid
Supervisor operational authority	DuckDB control.duckdb; typed Quack owner/client; StateTransaction CAS and idempotency	“The supervisor uses SQLite” or “each agent writes the database file directly”
Source input packaging	Read-only SkillCenter SQLite bundles; source Parquet/JSON-LD/HTML/WARC	“An input database format defines the runtime architecture”
Retrieval products	BM25, vectors, graphs and bounded Parquet shards keyed by source IDs/CIDs	“A retrieved neighbor is a grant or a proof”

Layer	Technology and inspected role	Incorrect inference to avoid
Immutable artifacts	Kit-managed content-addressed blocks, manifests, maps, proof/decision receipts, optional IPFS replication	“The newest block is automatically the accepted state”
Peer carriage	libp2p negotiated streams and MCP++ framing	“A peer identity grants tool permission”
Delegated capability	Strict signed UCAN verification and revocation/replay state	“A valid token proves the action is legally and semantically safe”

471 A caller supplies a named command and typed parameters, not a SQL string. The identical command
472 can retrieve a committed result after a lost reply; a changed payload with the same identity is a
473 conflict. The Quack gateway extension was unavailable under the sealed home and is not claimed.
474 IPFS answers which artifact bytes are requested; local CID computation proves neither publication
475 nor public availability. libp2p answers how peers connect. In-process framing is not libp2p network
476 evidence. Strict UCAN checks cryptographic issuer identity, delegation continuity, resource/ability
477 bounds, temporal validity, attenuation, revocation, and replay policy. It does not infer delegation from
478 natural-language text.

479 D Implementation trace

480 The portable supplement maps neutral analysis paths to original source commitments and separately
481 hashes the included path-normalized bytes. Private runtime credentials and the live store are not
482 distributed.

Table D1: Implementation-oriented trace. Compact LA-029 rows remain the scored outcomes; LA-020 retains intermediate artifacts on a separate diagnostic replay of frozen A4 identities.

Method	Representative implementation	Inputs inspected in a reproducible run
Legal routing	Deterministic deontic parser; typed canonical compiler	Dataset revision, source body, jurisdiction, source maps, unsupported facets
Skill import	SkillRecordAdapter and read-only bundle adapter	Physical source row, metadata, skill/library Markdown, entry/body identities
CVE adaptation	CVEFixesAdapter	Vulnerable/fixed source records, candidate scope, prohibition/control polarity
Constraint join	ConstraintCompiler	Candidate graph, legal/security/intent checks, proof requirements, current roots
Proof authorization	AuthorizationService; SAT child process plus truth-table checker	QF_BOOL jobs, satisfiability authority, rejected theorem_proof upgrades
Guarded execution	Pre-invocation enforcement wrapper in ENFORCE	Current live context, authenticated receipt, expiry/use state, delegate effects
State control	TypedStateClient; file-backed DuckDB consumption	Named command, generation, fence, revision, idempotency and committed result

483 A diagnostic replay of the permitted A4 identity recorded by LA-020 (seed 104729, skill case-0;
484 exact attempt identifier retained in the worked-trace record) ran source-pin resolution, Intent IR
485 derivation, exact tool/argument binding, QF_BOOL SAT (provider unsat, checker agrees, satisfiability

only), real Ed25519 UCAN allow, ENFORCE consume on the DuckDB owner, one export_json dispatch, and one independent journal event with useful work. Matched forbidden replays for wrong audience, undeclared effect, and replay denied at delegation or consumption with zero forbidden effects. LegallIRCompiler was not the selected adapter. Independent human review was not used. No fabricated signature or conceptual step is presented as executed.

E Resolved measurement inventory

Original Table E1 listed placeholders. Table E1 records the actual disposition. “Withdrawn” and “qualification only” are scoped omissions, not zeros invented from missing runs.

Table E1: Resolved measurement inventory. Withdrawn claims are unmeasured. Qualification suites are not scored arm rates. The primary protected-effect study is the admitted LA-029 matrix.

Measurement	Actual record	Disposition
Legal source-to-IR fidelity	Expert-reviewed atoms, exceptions, applicability and agreement	Withdrawn / unmeasured; replaced by automated span, schema, and machine-contract checks (60/60, 50/60, 60/60)
CVE restriction specificity	Vulnerable/fixed pairs and excluded controls	12 pairs / 24 cases and 84 excluded controls retained; source-difference 24/24; polarity unknown 24/24; no transfer claim
Skill grounding	Source spans and malicious Markdown negatives	Span linkage on all skill cases; 18/18 shared-producer schema conformance, not independent agreement; six unsupported policy-blocked rows
Proof job execution	Per-family provider/checker route	QF_BOOL SAT qualified; theorem kernels and QF_LIA interpolation unavailable, not invented
Guarded effect prevention	Delegate/effect counters under allow, deny, stale and replay	Admitted LA-029: A4 0/90 forbidden effects and 90/90 allowed useful work
DuckDB owner safety	Wrong generation/fence, concurrent commands, lost reply, restart	Qualification 14/14 selected-claim cases; in-memory restart is a labeled contrast; not a scored 900-cell rate
Cross-transport parity	Stdio/HTTP/P2P same request and outcome	Local-process and loopback qualification; WAN and IPFS daemon absent
End-to-end efficiency	Model tokens, retrieval, proof and state overhead	Development A4 instrumentation only; model tokens unobserved; no price conversion; not a 900-cell rescore
Closed-loop planning	Pinned-model generated programs and recovery	Explicitly withdrawn: 900/900 not started; 0 model calls; 0 generated programs

F Scope, ongoing work, and disclosure

Semantic-addressed program worlds, learned residuals, semantic-preserving refactoring, parallel sealing, and proof-carrying test reuse were unavailable for this revision and are not implemented contributions. Semantic minification and learned encoders were not evaluated as cost savings.

Language-model assistance supported source inspection, implementation and control development, execution orchestration, retained-data analysis, and manuscript drafting. Grok grok-4.6 (xAI) performed ordinary drafting and inspection; Codex (GPT-6) coordinated implementation, recovery,

501 analysis, and final artifact corrections. The configured Codex gpt-5.6-terra fallback is a config-
502 uration record, not evidence that it ran. These assistants were not scored experimental arms: the
503 admitted fixed-action matrix executed 0 scientific model calls, and A1/A2 are model-free labels.
504 Closed-loop generated-code planning was withdrawn unrun. No independent human legal, security,
505 or intent validation and no inter-annotator agreement study was collected. Optional author review is
506 non-independent, is not a prerequisite, and is not recorded as completed. Automated controls and
507 retained independent effect observations support the measured claims; they do not establish expert
508 legal fidelity or replace uncollected human judgments.

NeurIPS Paper Checklist

1. Claims

Question: Do the main claims made in the abstract and introduction accurately reflect the paper’s contributions and scope?

Answer: [Yes]

Justification: The abstract and introduction state the bounded ENFORCE contribution (admitted A4 0/90 forbidden effects and 90/90 allowed useful work) and explicitly withdraw expert legal fidelity, human agreement, and closed-loop planning.

Guidelines:

- The answer [N/A] means that the abstract and introduction do not include the claims made in the paper.
- The abstract and/or introduction should clearly state the claims made, including the contributions made in the paper and important assumptions and limitations. A [No] or [N/A] answer to this question will not be perceived well by the reviewers.
- The claims made should match theoretical and experimental results, and reflect how much the results can be expected to generalize to other settings.
- It is fine to include aspirational goals as motivation as long as it is clear that these goals are not attained by the paper.

2. Limitations

Question: Does the paper discuss the limitations of the work performed by the authors?

Answer: [Yes]

Justification: Section 6 records Legal/Security/Intent IR as lossy models, complete mediation only for one sandbox ENFORCE route, SAT-only authority, withdrawn closed-loop planning, and unmeasured expert review.

Guidelines:

- The answer [N/A] means that the paper has no limitation while the answer [No] means that the paper has limitations, but those are not discussed in the paper.
- The authors are encouraged to create a separate “Limitations” section in their paper.
- The paper should point out any strong assumptions and how robust the results are to violations of these assumptions (e.g., independence assumptions, noiseless settings, model well-specification, asymptotic approximations only holding locally). The authors should reflect on how these assumptions might be violated in practice and what the implications would be.
- The authors should reflect on the scope of the claims made, e.g., if the approach was only tested on a few datasets or with a few runs. In general, empirical results often depend on implicit assumptions, which should be articulated.
- The authors should reflect on the factors that influence the performance of the approach. For example, a facial recognition algorithm may perform poorly when image resolution is low or images are taken in low lighting. Or a speech-to-text system might not be used reliably to provide closed captions for online lectures because it fails to handle technical jargon.
- The authors should discuss the computational efficiency of the proposed algorithms and how they scale with dataset size.
- If applicable, the authors should discuss possible limitations of their approach to address problems of privacy and fairness.
- While the authors might fear that complete honesty about limitations might be used by reviewers as grounds for rejection, a worse outcome might be that reviewers discover limitations that aren’t acknowledged in the paper. The authors should use their best judgment and recognize that individual actions in favor of transparency play an important role in developing norms that preserve the integrity of the community. Reviewers will be specifically instructed to not penalize honesty concerning limitations.

3. Theory assumptions and proofs

Question: For each theoretical result, does the paper provide the full set of assumptions and a complete (and correct) proof?

Answer: [N/A]

Justification: The paper reports an empirical runtime-checking measurement and a qualified QF_BOOL SAT route with satisfiability authority only; it does not state numbered theorems with complete proofs.

Guidelines:

- The answer [N/A] means that the paper does not include theoretical results.
- All the theorems, formulas, and proofs in the paper should be numbered and cross-referenced.
- All assumptions should be clearly stated or referenced in the statement of any theorems.
- The proofs can either appear in the main paper or the supplemental material, but if they appear in the supplemental material, the authors are encouraged to provide a short proof sketch to provide intuition.
- Inversely, any informal proof provided in the core of the paper should be complemented by formal proofs provided in appendix or supplemental material.
- Theorems and Lemmas that the proof relies upon should be properly referenced.

4. Experimental result reproducibility

Question: Does the paper fully disclose all the information needed to reproduce the main experimental results of the paper to the extent that it affects the main claims and/or conclusions of the paper (regardless of whether the code and data are provided or not)?

Answer: [Yes]

Justification: Section 5 and the anonymous supplement pin the 30-family/60-case protocol, five arms, seeds, implementation revision, Docker image digest, and a one-command bounded reproduce path from hashed raw records.

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- If the paper includes experiments, a [No] answer to this question will not be perceived well by the reviewers: Making the paper reproducible is important, regardless of whether the code and data are provided or not.
- If the contribution is a dataset and/or model, the authors should describe the steps taken to make their results reproducible or verifiable.
- Depending on the contribution, reproducibility can be accomplished in various ways. For example, if the contribution is a novel architecture, describing the architecture fully might suffice, or if the contribution is a specific model and empirical evaluation, it may be necessary to either make it possible for others to replicate the model with the same dataset, or provide access to the model. In general, releasing code and data is often one good way to accomplish this, but reproducibility can also be provided via detailed instructions for how to replicate the results, access to a hosted model (e.g., in the case of a large language model), releasing of a model checkpoint, or other means that are appropriate to the research performed.
- While NeurIPS does not require releasing code, the conference does require all submissions to provide some reasonable avenue for reproducibility, which may depend on the nature of the contribution. For example
 - (a) If the contribution is primarily a new algorithm, the paper should make it clear how to reproduce that algorithm.
 - (b) If the contribution is primarily a new model architecture, the paper should describe the architecture clearly and fully.
 - (c) If the contribution is a new model (e.g., a large language model), then there should either be a way to access this model for reproducing the results or a way to reproduce the model (e.g., with an open-source dataset or instructions for how to construct the dataset).

- (d) We recognize that reproducibility may be tricky in some cases, in which case authors are welcome to describe the particular way they provide for reproducibility. In the case of closed-source models, it may be that access to the model is limited in some way (e.g., to registered users), but it should be possible for other researchers to have some path to reproducing or verifying the results.

5. Open access to data and code

Question: Does the paper provide open access to the data and code, with sufficient instructions to faithfully reproduce the main experimental results, as described in supplemental material?

Answer: [Yes]

Justification: The anonymous ZIP includes all 9,933 retained reducer inputs, the executed controller/driver/cell/reducer source lineage with separate original and portable hashes, and an offline analysis command. Full native binaries, private keys, and source corpus bodies are not distributed; this is retained-data reproduction, not a fresh scientific rerun.

Guidelines:

- The answer [N/A] means that paper does not include experiments requiring code.
- Please see the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- While we encourage the release of code and data, we understand that this might not be possible, so [No] is an acceptable answer. Papers cannot be rejected simply for not including code, unless this is central to the contribution (e.g., for a new open-source benchmark).
- The instructions should contain the exact command and environment needed to run to reproduce the results. See the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- The authors should provide instructions on data access and preparation, including how to access the raw data, preprocessed data, intermediate data, and generated data, etc.
- The authors should provide scripts to reproduce all experimental results for the new proposed method and baselines. If only a subset of experiments are reproducible, they should state which ones are omitted from the script and why.
- At submission time, to preserve anonymity, the authors should release anonymized versions (if applicable).
- Providing as much information as possible in supplemental material (appended to the paper) is recommended, but including URLs to data and code is permitted.

6. Experimental setting/details

Question: Does the paper specify all the training and test details (e.g., data splits, hyperparameters, how they were chosen, type of optimizer) necessary to understand the results?

Answer: [Yes]

Justification: Section 5.1 specifies lineage splits, seeds, matched arms, the selected ENFORCE handler, independent journal counters, and the frozen modeled policy; resource and mechanism pins are in the supplement.

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The experimental setting should be presented in the core of the paper to a level of detail that is necessary to appreciate the results and make sense of them.
- The full details can be provided either with the code, in appendix, or as supplemental material.

7. Experiment statistical significance

Question: Does the paper report error bars suitably and correctly defined or other appropriate information about the statistical significance of the experiments?

Answer: [Yes]

Justification: Section 5.3 reports stratified paired family-bootstrap intervals with 2,000 draws and seed 104729, retaining paired cases and seeds within each family. Wilson/Clopper-Pearson intervals belong to historical diagnostic analyses and are not the primary admitted-study intervals; a degenerate zero interval does not prove population-level absence.

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The authors should answer [Yes] if the results are accompanied by error bars, confidence intervals, or statistical significance tests, at least for the experiments that support the main claims of the paper.
- The factors of variability that the error bars are capturing should be clearly stated (for example, train/test split, initialization, random drawing of some parameter, or overall run with given experimental conditions).
- The method for calculating the error bars should be explained (closed form formula, call to a library function, bootstrap, etc.)
- The assumptions made should be given (e.g., Normally distributed errors).
- It should be clear whether the error bar is the standard deviation or the standard error of the mean.
- It is OK to report 1-sigma error bars, but one should state it. The authors should preferably report a 2-sigma error bar than state that they have a 96% CI, if the hypothesis of Normality of errors is not verified.
- For asymmetric distributions, the authors should be careful not to show in tables or figures symmetric error bars that would yield results that are out of range (e.g., negative error rates).
- If error bars are reported in tables or plots, the authors should explain in the text how they were calculated and reference the corresponding figures or tables in the text.

8. Experiments compute resources

Question: For each experiment, does the paper provide sufficient information on the computer resources (type of compute workers, memory, time of execution) needed to reproduce the experiments?

Answer: [Yes]

Justification: Section 5.3 reports 1608.817478 descendant-inclusive CPU seconds, peak cell memory 274812928 bytes, and 902 host attempts. The maximum individual-cell wall-to-exit is 18.022665 seconds; cumulative active startup-recovery wall is separately 11.766052 and 19.793533 seconds, with operator pause gaps excluded and retained.

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The paper should indicate the type of compute workers CPU or GPU, internal cluster, or cloud provider, including relevant memory and storage.
- The paper should provide the amount of compute required for each of the individual experimental runs as well as estimate the total compute.
- The paper should disclose whether the full research project required more compute than the experiments reported in the paper (e.g., preliminary or failed experiments that didn't make it into the paper).

9. Code of ethics

Question: Does the research conducted in the paper conform, in every respect, with the NeurIPS Code of Ethics <https://neurips.cc/public/EthicsGuidelines>?

Answer: [Yes]

Justification: The study uses public legal texts and retrieval-only vulnerability/skill sources, involves no human subjects, preserves double-blind anonymity, and does not redistribute source bodies or exploit payloads.

Guidelines:

- The answer [N/A] means that the authors have not reviewed the NeurIPS Code of Ethics.

- If the authors answer [No], they should explain the special circumstances that require a deviation from the Code of Ethics.
- The authors should make sure to preserve anonymity (e.g., if there is a special consideration due to laws or regulations in their jurisdiction).

10. Broader impacts

Question: Does the paper discuss both potential positive societal impacts and negative societal impacts of the work performed?

Answer: [No]

Justification: The paper discusses technical claim limits of runtime enforcement and withdrawn legal-fidelity studies, but it does not include a dedicated positive-and-negative societal-impact analysis.

Guidelines:

- The answer [N/A] means that there is no societal impact of the work performed.
- If the authors answer [N/A] or [No], they should explain why their work has no societal impact or why the paper does not address societal impact.
- Examples of negative societal impacts include potential malicious or unintended uses (e.g., disinformation, generating fake profiles, surveillance), fairness considerations (e.g., deployment of technologies that could make decisions that unfairly impact specific groups), privacy considerations, and security considerations.
- The conference expects that many papers will be foundational research and not tied to particular applications, let alone deployments. However, if there is a direct path to any negative applications, the authors should point it out. For example, it is legitimate to point out that an improvement in the quality of generative models could be used to generate Deepfakes for disinformation. On the other hand, it is not needed to point out that a generic algorithm for optimizing neural networks could enable people to train models that generate Deepfakes faster.
- The authors should consider possible harms that could arise when the technology is being used as intended and functioning correctly, harms that could arise when the technology is being used as intended but gives incorrect results, and harms following from (intentional or unintentional) misuse of the technology.
- If there are negative societal impacts, the authors could also discuss possible mitigation strategies (e.g., gated release of models, providing defenses in addition to attacks, mechanisms for monitoring misuse, mechanisms to monitor how a system learns from feedback over time, improving the efficiency and accessibility of ML).

11. Safeguards

Question: Does the paper describe safeguards that have been put in place for responsible release of data or models that have a high risk for misuse (e.g., pre-trained language models, image generators, or scraped datasets)?

Answer: [N/A]

Justification: The submission does not release pretrained generative models, image generators, or scraped web-scale datasets; source bodies remain retrieval-only with hashes.

Guidelines:

- The answer [N/A] means that the paper poses no such risks.
- Released models that have a high risk for misuse or dual-use should be released with necessary safeguards to allow for controlled use of the model, for example by requiring that users adhere to usage guidelines or restrictions to access the model or implementing safety filters.
- Datasets that have been scraped from the Internet could pose safety risks. The authors should describe how they avoided releasing unsafe images.
- We recognize that providing effective safeguards is challenging, and many papers do not require this, but we encourage authors to take this into account and make a best faith effort.

12. Licenses for existing assets

Question: Are the creators or original owners of assets (e.g., code, data, models), used in the paper, properly credited and are the license and terms of use explicitly mentioned and properly respected?

Answer: [Yes]

Justification: Independent sources are cited with pinned revisions; the supplement records GovInfo U.S. government works, CVEfixes packaging Apache-2.0 with upstream code licenses still governing, and SkillCenter packaging MIT that does not grant nested-source rights.

Guidelines:

- The answer [N/A] means that the paper does not use existing assets.
- The authors should cite the original paper that produced the code package or dataset.
- The authors should state which version of the asset is used and, if possible, include a URL.
- The name of the license (e.g., CC-BY 4.0) should be included for each asset.
- For scraped data from a particular source (e.g., website), the copyright and terms of service of that source should be provided.
- If assets are released, the license, copyright information, and terms of use in the package should be provided. For popular datasets, paperswithcode.com/datasets has curated licenses for some datasets. Their licensing guide can help determine the license of a dataset.
- For existing datasets that are re-packaged, both the original license and the license of the derived asset (if it has changed) should be provided.
- If this information is not available online, the authors are encouraged to reach out to the asset's creators.

13. New assets

Question: Are new assets introduced in the paper well documented and is the documentation provided alongside the assets?

Answer: [Yes]

Justification: The anonymous ZIP documents retained observations, source and runtime provenance, the offline analysis route and its limits, constructed measurement-integrity controls, and source-retrieval instructions. Actual recovery source and cost lineage accompany the compact outcomes; no private runtime key, live store, or author-maintained repository URL is supplied.

Guidelines:

- The answer [N/A] means that the paper does not release new assets.
- Researchers should communicate the details of the dataset/code/model as part of their submissions via structured templates. This includes details about training, license, limitations, etc.
- The paper should discuss whether and how consent was obtained from people whose asset is used.
- At submission time, remember to anonymize your assets (if applicable). You can either create an anonymized URL or include an anonymized zip file.

14. Crowdsourcing and research with human subjects

Question: For crowdsourcing experiments and research with human subjects, does the paper include the full text of instructions given to participants and screenshots, if applicable, as well as details about compensation (if any)?

Answer: [N/A]

Justification: The amended study collected no crowdsourcing and no research with human subjects; expert review was not obtained and those claims were withdrawn.

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.

- Including this information in the supplemental material is fine, but if the main contribution of the paper involves human subjects, then as much detail as possible should be included in the main paper.
- According to the NeurIPS Code of Ethics, workers involved in data collection, curation, or other labor should be paid at least the minimum wage in the country of the data collector.

15. **Institutional review board (IRB) approvals or equivalent for research with human subjects**

Question: Does the paper describe potential risks incurred by study participants, whether such risks were disclosed to the subjects, and whether Institutional Review Board (IRB) approvals (or an equivalent approval/review based on the requirements of your country or institution) were obtained?

Answer: [N/A]

Justification: No human-subjects protocol was conducted, so no IRB or equivalent review was required or obtained.

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.
- Depending on the country in which research is conducted, IRB approval (or equivalent) may be required for any human subjects research. If you obtained IRB approval, you should clearly state this in the paper.
- We recognize that the procedures for this may vary significantly between institutions and locations, and we expect authors to adhere to the NeurIPS Code of Ethics and the guidelines for their institution.
- For initial submissions, do not include any information that would break anonymity (if applicable), such as the institution conducting the review.

16. **Declaration of LLM usage**

Question: Does the paper describe the usage of LLMs if it is an important, original, or non-standard component of the core methods in this research? Note that if the LLM is used only for writing, editing, or formatting purposes and does *not* impact the core methodology, scientific rigor, or originality of the research, declaration is not required.

Answer: [N/A]

Justification: LLMs are not part of the scored runtime-enforcement mechanism, and the admitted fixed-action study made 0 scientific model calls. Appendix F and the disclosure file nevertheless record Grok and Codex assistance in implementation, control development, execution orchestration, analysis, and writing; configured fallback metadata is not presented as observed use.

Guidelines:

- The answer [N/A] means that the core method development in this research does not involve LLMs as any important, original, or non-standard components.
- Please refer to our LLM policy in the NeurIPS handbook for what should or should not be described.